


OpenIDX

Zero Trust Access Platform · Self-Hosted · Open Source

Four identity products. One platform. One database.

OpenIDX unifies **identity management (IAM)**, **governance (IGA)**, **privileged access (PAM)**, and a **zero-trust network plane (ZTNA)** — work you normally buy as four separate products — into a single self-hostable platform over one PostgreSQL database. It is built to replace a stack of Microsoft Entra ID + Okta + SailPoint + CyberArk + Zscaler at **70–80% below** their stacked per-user pricing.

70–80%

savings vs. the stacked incumbent bill

4 → 1

one platform instead of four SKUs

≤30 s

end-to-end access revocation (kill switch)

IAM
Identity

OIDC/SAML SSO, MFA (passkey/TOTP/push), LDAP/AD/Azure AD sync, SCIM 2.0, adaptive risk.

IGA
Governance

Access reviews, SoD (fail-closed), JIT elevation, approval workflows, HR-driven JML.

PAM
Privileged Access

Encrypted vault + rotation, SSH/RDP/VNC brokering, session recording, credential injection.

ZTNA
Zero Trust Network

OpenZiti "dark" services (no open ports), clientless BrowZer, posture-checked agents.

"One revoke decision deletes the grant, kills the session, terminates the privileged connection, and severs the network circuit in under 30 seconds — in a single hash-chained audit trail."

This is OpenIDX's real moat: because all four pillars share one control plane, a decision is a single database write — not a multi-connector integration project.

Why now? — The market is consolidating

INCUMBENTS ARE ASSEMBLING THIS BY M&A

- **\$25 billion** Palo Alto × CyberArk (Feb 2026)
- Okta × Axiom · Delinea × StrongDM · SailPoint IPO
- Everyone is buying "identity-to-network-packet" together.

THE PRICING REVOLT IS REAL

- Okta: ~\$204/user/yr (Essentials); governance is a separate SKU
- Auth0: **15× bill growth** on 1.67× user growth (documented)
- CyberArk: \$1.8K–12K/user/yr, quote-only
- PAM broadly: \$9–400/user/yr, multi-year commit

- **OpenIDX already is that, in one codebase.**

What's marketable — the packaging map

Not one giant SKU; packageable modules by buyer tier. The core stays open source (Apache-2.0) forever; the monetized layers are new-buyer features.

MODULE	SOLD TO	VALUE PROPOSITION	TIER
IAM / SSO core	Every organization	Fixed cost + self-host vs. Okta/Auth0	Open source
PAM Suite	Regulated sectors, IT ops	CyberArk/Delinea alternative, 90%+ cheaper	Enterprise
ZTNA / OpenZiti plane	Distributed workforce, OT/IoT, MSP	"Dark" services, no VPN, clientless	Enterprise
IGA / Governance	Compliance & audit	SailPoint alternative, audit evidence	Enterprise
Kill-Switch & Access 360	CISO / SOC	End-to-end revocation in one action ≤30 s	Enterprise
Compliance Packs	Regulated sectors	SOC2/ISO/GDPR/DORA audit-ready output	Add-on
Premium connectors	Enterprise integration	Workday, ServiceNow, extra rotation	Add-on
MSP orchestration + metering	Service providers	White-label multi-tenant, chargeback	MSP
FIPS / air-gap build	Defense, government	Certified, air-gapped deployment	Add-on

Pricing

Community Free Full core: IAM+IGA+PAM+ZTNA. Self-host. Community support. Apache-2.0.	Enterprise \$4–6/user/mo Floor ~\$6–8K/yr. SLA, compliance packs, premium connectors, priority support.	MSP Tenant + metered White-label, multi-tenant orchestration, usage metering & chargeback.	Gov / Defense Project-based FIPS/air-gap build, on-prem install, data-sovereignty positioning.
---	---	--	--

Comparison: the stacked incumbent bill is **\$33–65/user/mo**. OpenIDX Enterprise ~\$4–6 → the "70–80% savings" is substantiated by third-party pricing data.

Target segments

1 · SOVEREIGNTY-MANDATED PUBLIC SECTOR PRIORITY Regulations that bar foreign SaaS IdPs for identity/critical data (e.g. Türkiye Presidential Circular 2019/12, sector data-localization)	2 · EU NIS2 / DORA MID-MARKET - DORA's RTS is effectively a PAM mandate; NIS2 wants identity + privileged access + audit - No sovereign, self-hosted, four-pillar vendor
--	--

- Identity/SSO/PAM is the most sensitive data class → self-host is the only compliant path
- Ministries, municipalities, universities, hospitals, defense

exists → gap

3 · MSPS (MANAGED SERVICE PROVIDERS)

- White-label multi-tenant ZTNA is unserved in OSS
- FORCE-RLS multitenancy + metering fits exactly

4 · OSS-FIRST ENGINEERING ORGS

- Auth0-renewal and Teleport-license "refugees"
- Show HN / r/selfhosted funnel (the Infisical/Authentik model)

Deployment roadmap

Phases run independently so value arrives early. A typical pilot is 30–45 days.

- | | |
|---|--|
| <p>0 Discovery & scope (1–2 wks) — map the existing stack, choose the first value point (SSO+MFA or PAM access), define success criteria.</p> <p>1 Foundation (2–4 wks) — self-host (Docker/K8s), directory sync (LDAP/AD/Azure AD), first 2–3 apps on SSO + MFA, audit/SIEM/backup.</p> <p>2 Privileged access (2–4 wks) — critical servers into the vault, SSH/RDP/VNC brokering + recording, rotation, JIT + approvals.</p> | <p>3 Zero-trust network (3–6 wks) — OpenZiti overlay, critical services go "dark" (ports close), clientless/agent + posture, PAM targets moved onto the overlay.</p> <p>4 Governance & compliance (parallel) — access reviews, SoD, HR-driven JML, kill switch + Access 360, compliance reports, pentest.</p> <p>5 Go-live & scale — pilot → production, staged rollout, support/SLA, paid add-ons.</p> |
|---|--|

Proven capabilities (code-verified)

IDENTITY & ACCESS

- OAuth 2.0/OIDC (PKCE, refresh rotation, token exchange, JWKS rotation)
- SAML 2.0 IdP (XML-DSig, SP metadata, SLO)
- MFA: TOTP, WebAuthn/passkey, push, OTP + adaptive risk/step-up
- LDAP/AD/Azure AD sync, SCIM 2.0 (filter, PATCH)

PRIVILEGED ACCESS

- Envelope-encrypted vault + KEK rotation
- Rotation: SSH, AWS IAM, GCP SA, Postgres, MySQL, LDAP
- Guacamole SSH/RDP/VNC + credential injection, recording, legal hold
- Privileged sessions over OpenZiti — no inbound port on the target

GOVERNANCE

- Access reviews + certification (revocation enforced)
- SoD preventive, fail-closed; JIT + automatic expiry
- RBAC/ABAC/OPA; HR-driven Joiner/Mover/Leaver

ZERO-TRUST NETWORK & PLATFORM

- Identity-driven "dark" services, clientless BrowZer
- Desktop (signed Windows) + Android agent, posture
- Multi-tenant FORCE row-level security (CI-enforced)
- HMAC hash-chained audit + Elasticsearch, SIEM, Prometheus/OTel

Why OpenIDX?

① Four products, one platform, one DB — no integration debt · ② 70–80% cheaper, fixed cost · ③ Fully self-hosted, data sovereignty · ④ Regulations mandate self-host (2019/12, BDDK, DORA, NIS2) · ⑤ Kill switch: token → session → vault → network ≤30 s · ⑥ Apache-2.0, no lock-in

Maturity note: OpenIDX is at "MVP—early GA" — ready for design partners and paid pilots. Unqualified GA is pending a pentest and the CRA/ISO/SOC 2 compliance calendar. Pricing and savings figures are based on July 2026 third-party market data.

